ISO/IEC 42001 Compliance Control Matrix

System assessed: Contoso Ltd. customer-service chatbot (fictional scenario) **Standard:** ISO/IEC 42001, Annex A (8 controls) **Prepared by:** Merna Tarek **Date:** October 13, 2026

Method: Each control was compared with the Chatbot System Profile. A status was given only where the profile shows evidence. **Implemented** = fully in place; **Partial** = some parts in place; **Gap** = no formal evidence the control is addressed.

Summary

Implemented	Partial	Gap	Total
1	5	2	8

Highest-priority actions: document training data origin (A.4.3), publish user information (A.5.2), and create an AI-specific incident process (A.6.2).

Control Matrix

Control ID	Control Requirement	Status	Evidence (what exists)	Gap Note (what is missing)
A.2.2	Verify that the AI system meets the specified requirements before being put into service.	**Partial**	Section 4.0 (System Lifecycle and Validation): The chatbot completed user acceptance testing (UAT) before deployment. Test scripts confirm it answers the 50 most common customer questions correctly.	Testing covered only common questions. Expand validation to include stress testing and robustness testing against adversarial inputs, and record the results, before this control can be marked Implemented.
A.2.6	Establish processes for data quality evaluation, including for bias.	**Partial**	Section 3.0 (Data Management): The internal documents used for fine-tuning were reviewed for accuracy.	No formal process or testing checks the combined training data for bias. Establish a documented data quality process that assesses completeness, accuracy, relevance, and bias across all training data sources.
A.4.2	Establish and maintain clear lines of accountability for the AI system.	**Implemented**	Section 2.0 (Governance and Ownership): The Contoso AI Governance Charter (Doc ID: AI-GOV-01) formally names the Director of Digital Customer Experience as the AI System Owner, responsible for the chatbot's operation and performance.	None. Clear evidence shows this control is fully in place.
A.4.3	Document the provenance (origin) of data used for the AI system.	**Gap**	Section 3.0 (Data Management): The model was first trained on a large public language dataset, then fine-tuned on the internal "Product FAQ" and "Customer Service Policy" documents. No documentation was found that records where the public dataset came from.	There is no formal record of the origin of the public dataset. Document the full provenance of all training datasets (source, owner, date, and license) and confirm that usage rights are secured.
A.5.2	Provide users with sufficient information about the AI system and its purpose.	**Gap**	Section 5.0 (User Interface and Transparency): No documentation is available to end users. Internal teams have only a basic functional overview.	Users cannot find any description of the chatbot's function, capabilities, or limitations. Create and publish a short public notice (for example, an "About this assistant" page linked from the chat window).

Control ID	Control Requirement	Status	Evidence (what exists)	Gap Note (what is missing)
A.5.4	Clearly inform a person that they are interacting with an AI system.	**Partial**	Section 5.0 (User Interface and Transparency): At the start of a chat, a message shows for two seconds: "Now chatting with the Contoso Customer Assistant."	The message never says the assistant is an AI, and it disappears after two seconds. Change the wording to state clearly that the user is talking to an AI system, and keep the notice visible during the whole chat.
A.6.2	Establish a process to manage incidents related to the AI system's behavior and outputs.	**Partial**	Section 4.0 (System Lifecycle and Validation): The standard corporate IT incident process applies if the chatbot has a technical outage.	No AI-specific procedures exist for incorrect or harmful outputs. Expand the incident process to cover behavior and output incidents, including how they are reported, reviewed, and fixed.
A.7.1	Document the AI system's intended, unintended, and inappropriate uses.	**Partial**	Section 2.0 (Governance and Ownership): Section 2.1 of the Governance Charter defines the intended use as "providing automated, 24/7 customer support for common, non-sensitive queries."	The Charter does not define or prohibit unintended or inappropriate uses. Complete a risk assessment of possible misuse, then add the misuse scenarios and clear boundaries to the Charter.